

2026 Chicago SMB Email Security Report

Cover line: Barely 1 in 9 Chicago small businesses have their email authentication actually locked down.

Your domain is your front door. For most Chicago small businesses, it's unlocked.

Here's the gut-punch: on 2026-09-16 we checked the public DNS records of 410 Chicago small-business websites — dental practices, law firms, contractors, restaurants, real estate offices, professional services firms — and **54.6% of them have no DMARC record at all**. None. Not set to "monitor," not set to "quarantine," just... absent. Anyone on the internet can send an email that says it's from your business, and your mail server has published no instruction to stop it.

But that's only the start. **26.8% of businesses DO have a DMARC record — set to p=none**, which means "send me a report, but let the email through." It's a smoke detector with the batteries in a drawer.

Add those two groups together: **81.5% of Chicago small businesses scanned (334 of 410) have zero DMARC enforcement**. For every 10 local business domains you can name, 8 of them will let a forged email sail straight through.

Therefore the question isn't whether your business could be spoofed. It's whether your business has done the one thing that stops it.

KEY POINT: The single most important sentence in this report

Email authentication — SPF, DKIM, and DMARC — is a *published instruction* your domain gives to the world's mail servers: "only mail from my approved servers is real." **If you don't publish it, there is nothing to enforce**. An attacker doesn't need to hack your email. They just need to *pretend to be you* — to your customers, your vendors, your bookkeeper. And as of 2026-09-16, **8 in 10 Chicago small businesses haven't published the instruction**.

What attackers actually do with an unprotected domain

Forget Hollywood hacking. The real playbook is boring, cheap, and devastating:

- **Invoice fraud.** Your bookkeeper gets a "wire instructions updated" email from what looks exactly like your vendor. It isn't. The money is gone in an hour.
- **Customer phishing.** A patient, client, or customer gets an email "from" your office with a malicious attachment or a payment link. They trusted it because it carried your name.
- **Payroll diversion.** "HR" emails your payroll processor to reroute direct deposits. It came from a spoofed address at your own domain.
- **Reputation damage.** One wave of spam sent in your name, and your domain lands on blocklists. Your *real* email starts going to junk. Customers call asking why you're spamming them.

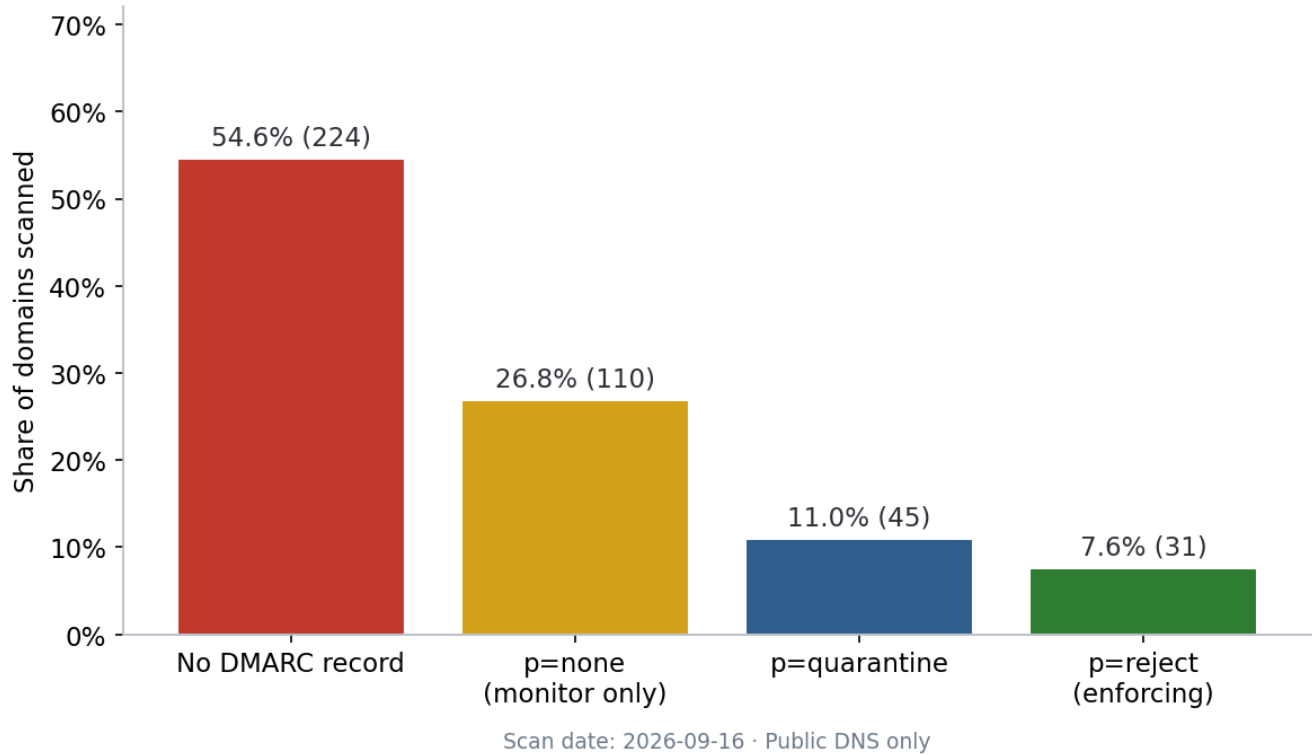
None of this requires breaking into anything. **It requires only that you haven't published a DMARC policy.** That's what 81.5% of the businesses we scanned are banking on — that nobody bothers.

KEY POINT: Loss-aversion check

A single successful invoice-fraud attack averages tens of thousands of dollars lost — and banks almost never reverse it. A proper SPF + DKIM + DMARC setup costs a few hundred dollars and about an hour or two of competent work. **You're not choosing between spending and saving. You're choosing between a \$1,000 fix and a \$50,000 loss.**

Finding 1: DMARC — the enforcement layer barely exists

DMARC posture of 410 Chicago SMB domains

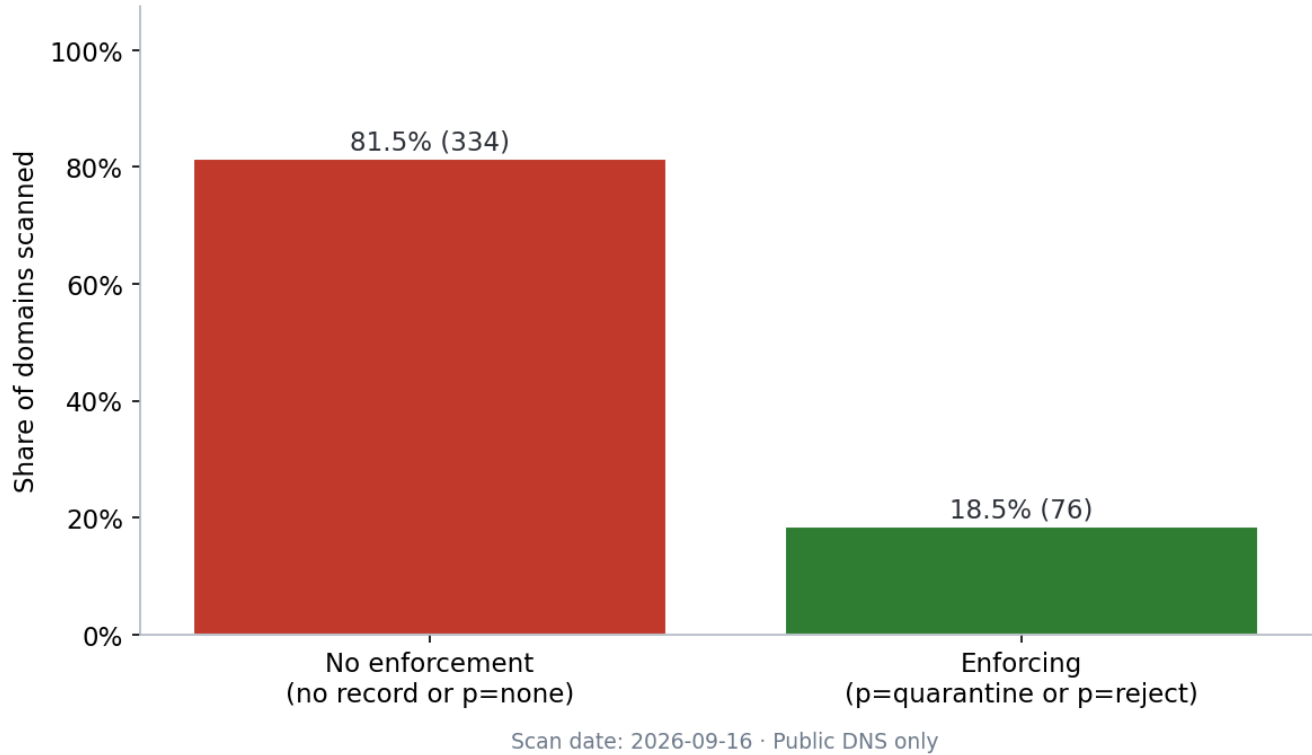


As of the 2026-09-16 scan:

DMARC status	Domains	Share
No DMARC record	224	54.6%
p=none (monitor only — no enforcement)	110	26.8%
p=quarantine (suspicious mail to spam)	45	11.0%
p=reject (forged mail blocked)	31	7.6%

What this means in plain English: More than half of businesses publish nothing at all. Another quarter published a policy that explicitly tells receivers *not* to block anything. **Together: 81.5% with no enforcement.** Only 76 of 410 domains (18.5%) tell the world to quarantine or reject mail that fails authentication.

Only 18.5% of domains enforce DMARC



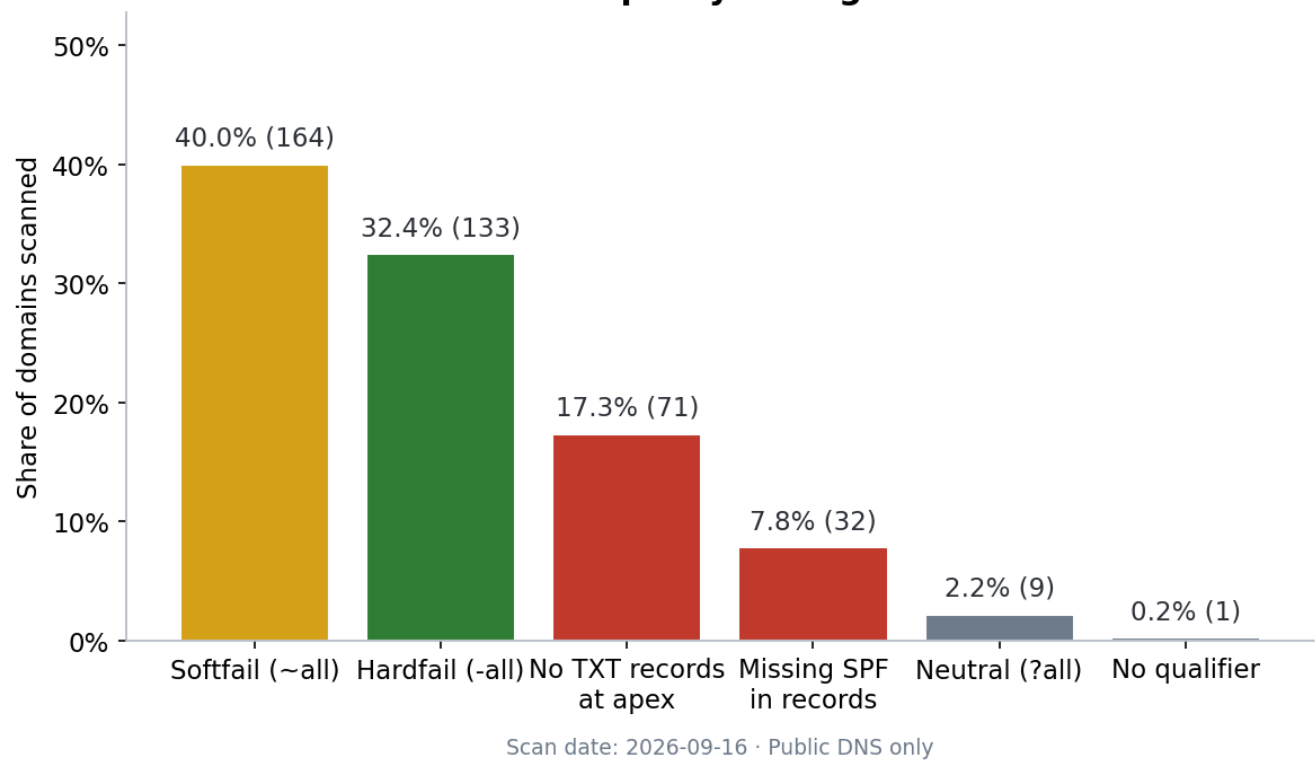
But wait — it gets worse for the businesses that actually receive email. Strip out the 65 domains with no mail records at all, and **49.0% of businesses that run live email still have no DMARC record**. These aren't dormant domains. They're actively used for business — and actively spoofable.

KEY POINT: Do this now

Open a terminal and run: `nslookup -type=TXT _dmarc.YOURDOMAIN.com` (Windows) or `dig TXT _dmarc.YOURDOMAIN.com` (Mac/Linux). If you get "no records," you are in the 54.6%. If the record says `p=none`, you are in the 26.8% that *thinks* they're protected. Both need fixing — and both are fixable in under two hours.

Finding 2: SPF — half-measures dominate, a third are solid

SPF policy strength



SPF tells the world which servers are allowed to send mail for your domain. As of 2026-09-16:

SPF status	Domains	Share
Softfail (~all — "probably not mine, deliver anyway")	164	40.0%
Hardfail (-all — "not mine, reject it")	133	32.4%
No TXT records at the apex at all	71	17.3%
Records exist but no SPF among them	32	7.8%
Neutral (?all)	9	2.2%
No qualifier	1	0.2%

The but/therefore here: SPF is the easiest record to publish — so a third of businesses did it right, with a hard fail. **But** the single most common SPF posture (40.0%) is *softfail*: a policy that politely suggests a forged email is suspicious, then delivers it anyway. That's a locked screen door. And 25.1% have no usable SPF at all (no TXT records, or records with no SPF in them).

Therefore: if your SPF ends in `~all`, you did 90% of the work and left the last 10% — the part that actually blocks anything — undone. Changing one character (`~` -> `-`) is the highest-ROI edit in email security.

Finding 3: DKIM — the invisible signature most businesses skip

57.3% of scanned domains (235 of 410) had **no DKIM selector detected** among the standard selectors checked (scan date 2026-09-16). DKIM is the cryptographic signature your mail server stamps on outgoing mail so receivers can prove it really came from you.

Why this matters to you: SPF checks the *envelope*; DKIM checks the *letter inside*. Without DKIM, even a good SPF policy is one hop away from being bypassed by forwarded mail. The two work as a pair — and most Chicago SMBs are missing one or both.

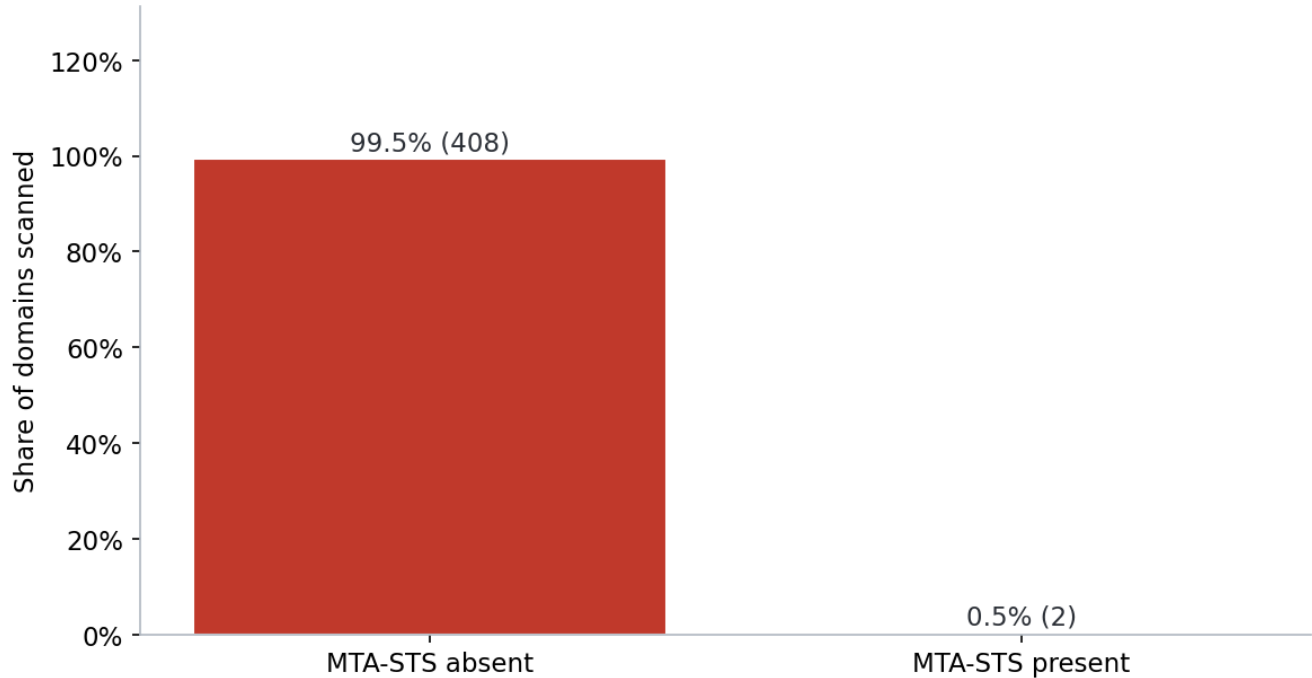
KEY POINT: The three-legged stool

- **SPF** = "these servers may send for me"
- **DKIM** = "this message is really mine, and it wasn't altered"
- **DMARC** = "here's what to do when SPF or DKIM fail"

One leg without the others wobbles. **Zero legs — where 54.6% of scanned businesses sit — is just the floor.**

Finding 4: MTA-STS — virtually nobody encrypts in transit

MTA-STS policy: nearly universal absence



Scan date: 2026-09-16 · Public DNS only

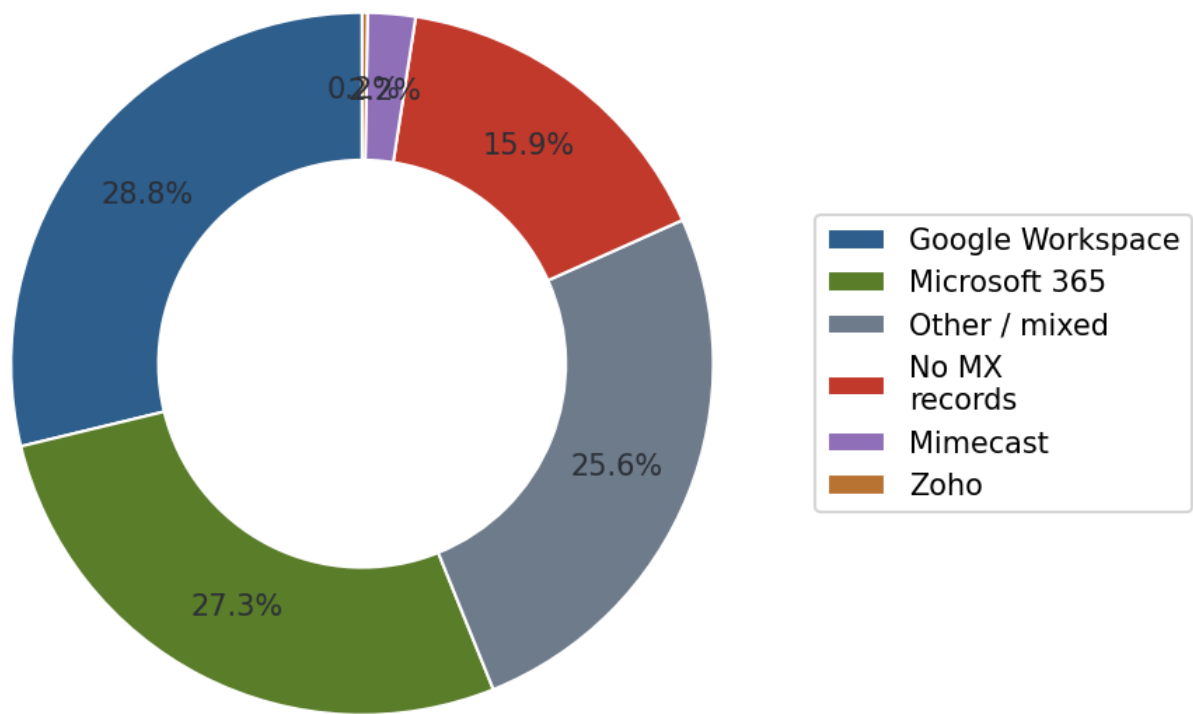
99.5% of scanned domains (408 of 410) have no MTA-STS policy as of 2026-09-16. Only 2 domains published one.

MTA-STS is the record that says "always encrypt mail to me in transit — never downgrade to plaintext." Without it, an attacker on the network path between mail servers can strip encryption and read email in transit. It's the least-known of the email security records, and the scan shows it: adoption is effectively zero.

This one is the canary. The businesses that have MTA-STS are the ones with someone paying attention. Everyone else — 99.5% — hasn't gotten there yet.

Finding 5: Where the mail actually lives

Where scanned domains host their mail



Scan date: 2026-09-16 · Public DNS only

Among the 410 domains scanned 2026-09-16, mail hosting breaks down as:

Mail host	Domains	Share
Google Workspace	118	28.8%
Microsoft 365	112	27.3%
Other / mixed providers	105	25.6%
No MX records (no mail at all)	65	15.9%
Mimecast	9	2.2%

Mail host	Domains	Share
Zoho	1	0.2%

The but/therefore: Google and Microsoft host the majority of Chicago SMB email — 56.1% combined. **But** the platforms already *support* SPF, DKIM, and DMARC out of the box; the records just were never published. Your mail provider gave you the locks. Nobody turned the key.

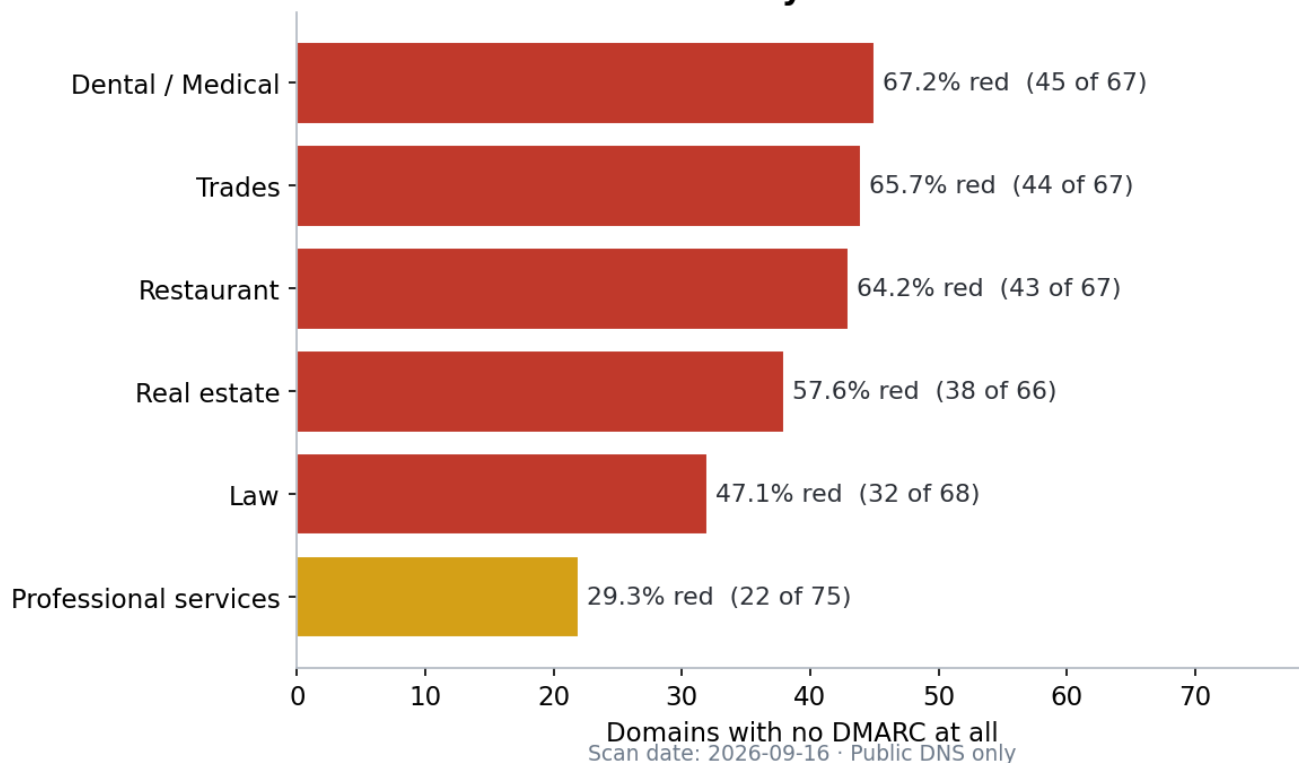
Therefore: if you're on Google Workspace or Microsoft 365, fixing this doesn't require changing providers, buying software, or migrating anything. It requires publishing three DNS records and flipping two toggles in your admin console. That's the entire project.

KEY POINT: Good news for M365 users specifically

Microsoft 365 has built-in anti-phishing and anti-spoofing policies (spoof intelligence, impersonation protection) that sit *on top of* DMARC. Most small businesses never turn them on. Enabling them takes minutes — and it's included in what you're already paying for.

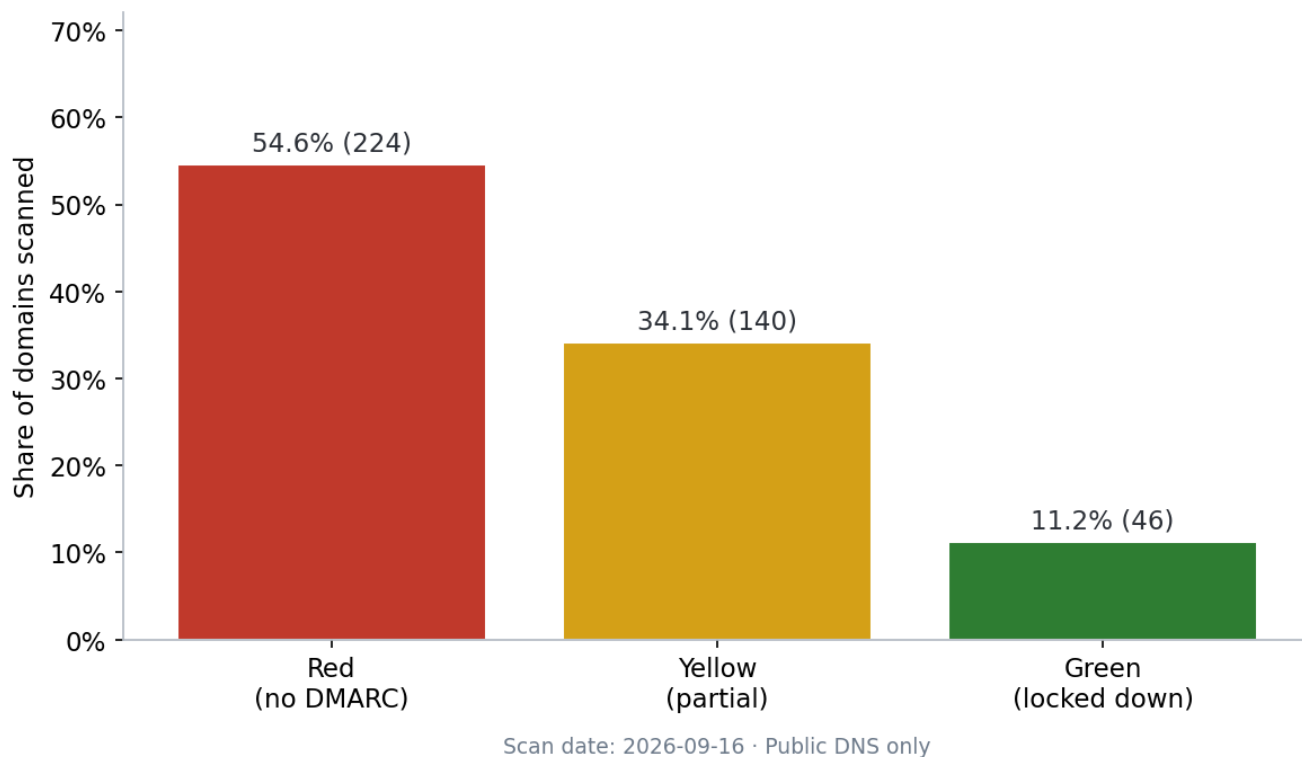
Finding 6: Some industries are in worse shape than others

Red score rate by business vertical



Overall scores (scan date 2026-09-16): **54.6% red** (224 — no DMARC at all), **34.1% yellow** (140 — partial protection), **11.2% green** (46 — DMARC quarantine/reject plus SPF hardfail).

Overall email authentication score



But the pain isn't evenly spread:

Vertical	Domains scanned	Red (no DMARC)	Red rate
Dental / Medical	67	45	67.2%
Trades (plumbing, electrical, HVAC, roofing, painters)	67	44	65.7%
Restaurant	67	43	64.2%
Real estate	66	38	57.6%
Law	68	32	47.1%
Professional services	75	22	29.3%

Read that top row twice. Dental and medical practices — businesses that email appointment reminders, treatment plans, and billing information, operating under HIPAA — have the worst email authentication posture in the city: **two out of three have no DMARC record whatsoever.**

Trades and restaurants aren't far behind at roughly two-thirds red each. These are the businesses whose customers get emailed invoices and payment links every single day — the exact attack surface invoice fraud lives on.

Professional services firms do best at 29.3% red — which is still nearly a third, and still worse than it should be for firms that often include IT and marketing consultants who should know better.

Illustrative scenarios matching common patterns in the scan (aggregates only — no real businesses): - *A dental practice on the South Side*: no DMARC, SPF softfail, no DKIM detected. Practices like this email appointment confirmations to patients. An attacker could send "your appointment moved — confirm by clicking here" to every patient on a stolen list. - *A roofing company serving the suburbs*: no DMARC, no SPF records at all. Contractors like this email estimates and invoices. A spoofed "updated wire instructions" email to a homeowner mid-project is a five-figure theft waiting to happen. - *A neighborhood restaurant group*: DMARC p=none, SPF softfail. Restaurants like this run gift-card promotions by email. Phishing "gift card balance check" emails in the restaurant's name would convert well — and poison the brand.

None of these are exotic attacks. They're the standard playbook, and the door is open.

What to do about it: the 4-step lockdown checklist

You don't need a security department. You need an afternoon and someone who knows DNS. Here's the whole program:

- [] **Step 1 — Publish SPF.** One TXT record at your domain apex listing every service allowed to send as you (your mail host, your website, your invoicing tool, your newsletter service). End it with `-all`, not `~all`.
- [] **Step 2 — Enable DKIM.** Generate the signing keys in your mail host's admin console (Google Workspace and M365 both walk you through it), publish the TXT records, flip it on.
- [] **Step 3 — Publish DMARC.** Start at `p=none` with a reporting address so you can see who's sending as you — then move to `p=quarantine`, then `p=reject`. Skipping straight to reject without the reporting phase is how legitimate mail gets blocked; do it in order.
- [] **Step 4 — Harden the mail platform.** In Microsoft 365: enable anti-phishing impersonation protection and spoof intelligence. In Google Workspace: enable the equivalent spoofing and authentication protections. Review them quarterly.

KEY POINT: Common trap to avoid

"My IT guy set up email years ago, so we're fine." The scan says otherwise for 8 in 10 businesses. **Email authentication wasn't standard practice when most of these domains were set up** — SPF/DKIM/DMARC adoption only became mainstream in the last few years. "It was set up professionally" and "it's set up securely" are two different claims. Check the records; don't assume.

Do this today

1. **Run the free checker on your own domain.** It reads the same public DNS records this report is built on — SPF, DKIM selectors, DMARC policy, MTA-STS, MX — and gives you a plain-English red/yellow/green verdict in seconds. No signup, no scan of anyone else's domain, just yours.
2. **Request the free one-page mini-audit.** You get your domain's full findings on one page: what's published, what's missing, and the exact records to add — written so you or your IT person can act on it immediately.
3. **Get it fixed in one shot.** The remediation sprint — SPF/DKIM/DMARC properly configured and Microsoft 365 anti-phishing hardened — runs **\$750–\$1,500** depending on domain complexity.

About one to two hours of work. Compare that to the invoice-fraud loss you're currently self-insuring against.

Where to go from here

This report is free. Fixing what it finds is the next step.

Start free: [IT Documentation Starter Pack](#) -- the runbooks and templates that turn "someone should fix email security" into an assigned, tracked task. Free on Gumroad.

Go deeper: the [Chicago IT Toolkit storefront](#) has ready-made kits built for exactly these problems:

- M365 Anti-Phishing Lockdown Kit (\$39) -- harden Exchange Online against the spoofing attacks this report describes
- M365 License Waste Audit Kit (\$39) -- find the licenses you're overpaying for while you're in the tenant
- Ransomware Tabletop Exercise Kit (\$39) -- test your incident response before an attacker does
- Shadow AI Discovery Kit (\$39) -- find the unsanctioned AI tools leaking company data
- Patch Sprint Playbook (\$39) -- get patching under control in one focused sprint

Every kit is a working template pack, not a webinar. 30-day money-back guarantee on all paid products.

Methodology (Appendix)

Scope and method. This report is based exclusively on public DNS lookups performed on 2026-09-16 via DNS-over-HTTPS (DoH). For each of 410 Chicago small-business domains, the scan queried: TXT records at the domain apex (for SPF), TXT records at `_dmarc.<domain>` (for DMARC policy), TXT records at standard DKIM selectors (`selector1`, `selector2`, `google`, `default`, `s1`, `s2`, `k1`), MX records (for mail host identification), and TXT records at `_mta-sts.<domain>` (for MTA-STS policy). No port scanning, no authentication attempts, no contact with the businesses, and no access to any private system was performed. Everything measured is information the domain owners already publish to the entire internet.

Scoring rubric. - **Red** = no DMARC record at all. - **Yellow** = DMARC present but set to `p=none` (no enforcement), OR SPF missing/softfail. - **Green** = DMARC set to `p=quarantine` or `p=reject` AND SPF set to `hardfail` (-all).

DKIM caveat. The scan checked only the seven listed selectors; a domain using a custom selector name would show as "no DKIM selector detected." The 57.3% figure is therefore a lower-bound signal of DKIM absence, not a definitive audit.

Point in time. DNS records change. These findings describe the state of the scanned domains on 2026-09-16 only. Businesses may have remediated since.

Sample. The 410 domains span six verticals — dental/medical (67), law (68), professional services (75), real estate (66), restaurant (67), trades (67) — drawn from public business listings and directories for the Chicago area. It is a convenience sample of small businesses with public websites, not a census. Aggregates only are published; no business names appear in this report.

Privacy. This report contains aggregate statistics only. No company names, no "wall of shame," no per-domain callouts. The scan exists solely as the basis for these aggregates. Readers checking their own posture should use the free checker on their own domains.

Report published 2026-09-22. All statistics labeled with scan date 2026-09-16. See Methodology for details.